

BURP SUITE INTRODUCTION & SAFE LAB SETUP

Name:- Rishabh Raj

1. What is Burp Suite?

Burp Suite is a web application security testing platform developed by PortSwigger. It helps testers inspect and analyze HTTP/HTTPS requests and responses in an authorized test environment. The Community Edition provides core tools for manual testing and learning.

2. Why is Burp Suite useful for web application security?

It lets a tester see how a browser communicates with a web application, understand request and response data, and manually examine application behavior. This can help identify security weaknesses during an authorized assessment.

3. What is Burp Proxy?

Burp Proxy is an intercepting web proxy between a browser and a web server. It can capture requests and responses so a tester can inspect them, and, when interception is enabled, pause a request before it is forwarded.

4. Explain the Browser → Burp → Web Server flow.

The browser sends a request to Burp Proxy. Burp displays or intercepts it according to its settings. When the request is forwarded, Burp sends it to the web server. The server's response returns through Burp and then reaches the browser. This allows the tester to inspect the communication in an authorized lab.

5. What does Intercept ON mean?

Intercept ON means Burp Proxy pauses matching requests or responses so the user can inspect them before they continue. A paused request will not reach the server until it is forwarded or otherwise handled.

6. What does Intercept OFF mean?

Intercept OFF means Burp does not pause traffic in the Proxy interception view. Requests and responses continue automatically, though they may still be recorded in HTTP history if logging is enabled.

7. What does Forward do?

Forward releases the currently intercepted message and lets it continue to its destination. For a request, this allows it to proceed toward the server; for a response, it allows it to proceed back toward the browser.

8. What is Burp's built-in browser?

Burp's built-in browser is a Chromium-based browser provided within Burp Suite and configured to work with Burp Proxy. It allows users to browse through the proxy without manually configuring a separate browser.

9. Why is the built-in browser useful for beginners?

It reduces setup work because it is already configured to use Burp Proxy. This makes it easier for beginners to focus on understanding requests, responses and interception rather than troubleshooting browser proxy settings or certificates.

10. What is HTTP History?

HTTP History is a record of web requests and responses that pass through Burp Proxy. It lets a tester revisit captured traffic and inspect its details after the browser interaction has completed.

11. What information can HTTP History show?

Depending on the entry and available data, HTTP History can show the host, URL, HTTP method, status code, request and response headers, parameters, and message bodies. It may also show timing and other metadata. Sensitive data should not be exposed in screenshots or shared reports.

12. What is a target?

A target is the application, host, or system that a security tester is authorized to assess. In Burp, target-related tools help organize the hosts and URLs observed during testing.

13. What is scope?

Scope defines which hosts, URLs, or application areas are included in an assessment and which are excluded. Setting scope helps keep testing limited to the approved target and reduces the chance of interacting with unrelated systems.

14. Why must a security tester have authorization?

Testing without permission can disrupt services, expose private information, violate policies, and break laws. Written authorization defines what may be tested, when, and by whom. A tester should stay within that approved scope.

15. What is Burp Repeater?

Repeater is a Burp tool for manually sending an HTTP request repeatedly and viewing each response. It is useful for understanding how an application

responds to a request. In this assignment, it should be used only with the unchanged, harmless example.com request specified by the instructor.

16. Explain the HTTP History → Send to Repeater → Send → Response workflow.

First, select the authorized example.com entry in HTTP History and review it. Send that request to Repeater. In Repeater, keep the request unchanged and select Send. Burp sends it and displays the server's response, which can be inspected in the response panel. This demonstrates request/response analysis without attempting to bypass controls or test vulnerabilities.

17. What is the difference between an HTTP request and response?

An HTTP request is sent by a client to ask a server for a resource or action. It typically contains a method, path, headers and sometimes a body. An HTTP response is sent by the server and contains a status code, headers and sometimes a body describing the result.

18. What sensitive information should never appear in student screenshots?

Screenshots should not expose passwords, session cookies, authorization headers, API keys, access tokens, private messages, personal or financial

information, or another person's traffic. Use only the approved lab and review or redact sensitive fields before submission.

19. Why should students not test random public websites?

A public website is not automatically an authorized testing target. Sending crafted requests or probing it may affect real users or systems and may violate law or terms of service. Students should use only instructor-approved targets, their own applications, or deliberately provided training environments.

20. Explain the purpose of Day 20 in your own words.

The purpose of Day 20 is to introduce Burp Suite and teach the safe fundamentals of web traffic inspection. By using the built-in browser, Proxy, HTTP History and Repeater with an unchanged example.com request, I can understand how requests travel between a browser and server. The assignment also emphasizes authorization, scope, privacy and responsible handling of screenshots.

Screenshot:-

1. Open Burp Suite Community Edition and start a temporary project using the default settings.

The screenshot displays the Burp Suite Community Edition interface. The top navigation bar includes tabs for Dashboard, Target, Proxy, Intruder, Repeater, Collaborator, Sequencer, Decoder, Comparer, Logger, Organizer, Extensions, and Discover. A notification banner at the top right encourages upgrading to Burp Suite Pro.

The left sidebar contains a 'Tasks' section with buttons for 'New scan' and 'New live task'. Below these are icons for pausing, settings, and help. A search bar is also present. A task card for '1. Live passive crawl from Proxy (all traffic)' is visible, showing a description and a 'Capturing' toggle switch.

The main workspace shows the configuration for the selected task. The 'Summary' tab is active, displaying a table for 'Items added to site map' with columns for Host, Method, URL, Status c..., and MIME type. The table is currently empty, with a message stating 'No items to show' and 'Items found in the crawl will display here.' A 'View site map' link is available.

The 'Task configuration' panel on the right shows the following details:

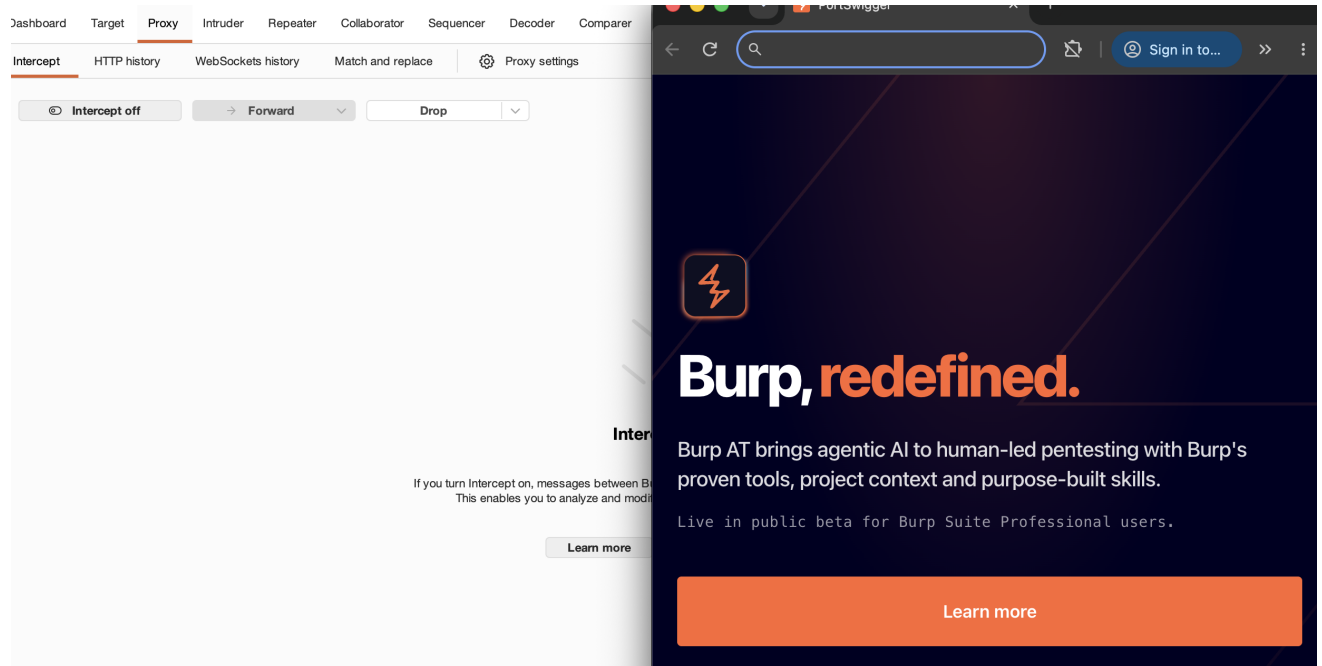
- Task type:** Live passive crawl
- Scope:** Proxy (all traffic)
- Configuration:** Add links. Add item itself, same domain and URLs in suite scope.
- Capturing:** Enabled (toggle switch)

The 'Task progress' section shows the following statistics:

- Site map items added: 0
- Responses processed: 0
- Responses queued: 0

The 'Task log' section is currently empty.

1. Open Proxy → Intercept and launch Burp's built-in browser.



1. Turn Intercept ON, then visit https://example.com/ as directed in the assignment.

